

Table 3: PENTESTAGENT’s performance among HackTheBox CTF challenges

Machine	Difficulty	Completed Stage
Sau	Easy	2/3 (I.G, V.A)
Pilgrimage	Easy	1/3 (V.A)
Lame	Easy	3/3
Topology	Easy	3/3
PC	Easy	3/3
Blue	Easy	3/3
Shocker	Easy	2/3 (V.A., E)
Optimum	Easy	3/3
Legacy	Easy	3/3
Stratosphere	Medium	2/3 (V.A., E)
Reel	Hard	2/3 (V.A, E.)

Table 4: PENTESTGPT’s performance among HackTheBox CTF challenges

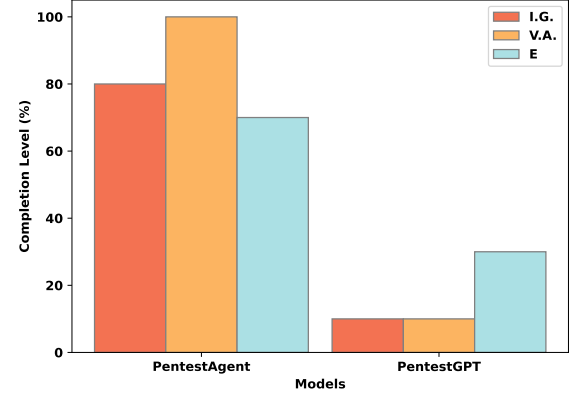
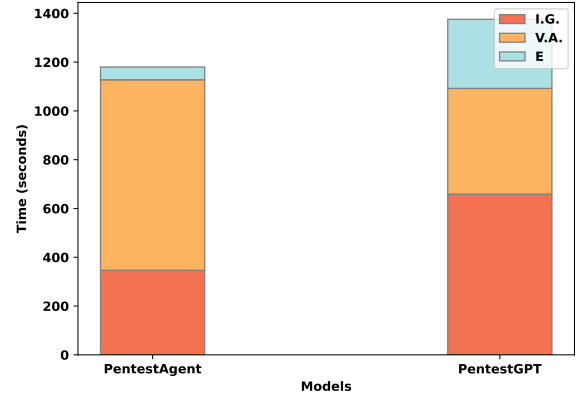
Machine	Difficulty	Completed Stage
Sau	Easy	2/3 (I.G, V.A)
Pilgrimage	Easy	1/3 (V.A)
Lame	Easy	2/3 (V.A., E)
Topology	Easy	2/3 (V.A., E)
PC	Easy	0/3
Blue	Easy	2/3 (V.A., E)
Shocker	Easy	0/3
Optimum	Easy	3/3
Legacy	Easy	3/3
Stratosphere	Medium	0/3
Reel	Hard	1/3 (I.G.)

contributing to vulnerable and outdated components ranking 6th on the OWASP Top 10 Web Application Security Risks. [34] Additionally, while our benchmark dataset features known vulnerabilities, we selected environments based on their Exploit Prediction Scoring System (EPSS) scores. These scores reflect the likelihood of a vulnerability being exploited in real-world scenarios. The dataset’s mean EPSS score is 79.58, with a median of 97.19, indicating that the vulnerabilities represented are highly likely to exist and be exploitable in practical settings. Moreover, finding open datasets containing zero-day or even one-day vulnerable environments remains challenging. By focusing on known vulnerabilities with high EPSS scores, our evaluation ensures that PENTESTAGENT operates within a realistic and credible context, assessing its effectiveness in addressing vulnerabilities that pose genuine risks to cybersecurity.

C Additional Evaluation Results

The detailed pentesting performance of both systems on HackTheBox challenges are available in Table 3 and Table. 4.

In addition to the HackTheBox evaluation, we compare PENTESTAGENT and PENTESTGPT on VulHub targets, analyzing both completion levels and overhead, as shown in Fig. 15 and Fig. 16.

**Figure 15: Comparison of completion levels on VulHub targets****Figure 16: Comparison of average time spent on VulHub targets**

PENTESTAGENT significantly outperformed PENTESTGPT across all penetration testing stages. In intelligence gathering, PENTESTAGENT achieved an 80% completion rate, compared to only 10% for PENTESTGPT, demonstrating its superior ability to extract relevant target information. In vulnerability analysis, PENTESTAGENT completed 100% of the tasks, whereas PENTESTGPT again achieved just 10%, highlighting its limited capability in identifying and assessing vulnerabilities. During exploitation, PENTESTAGENT successfully completed 70% of tasks, more than double PENTESTGPT’s 30%, confirming its stronger execution capabilities.

Efficiency is crucial in penetration testing automation, and PENTESTAGENT consistently required less time than PENTESTGPT in key stages. It completed intelligence gathering in 212.9 seconds, whereas PENTESTGPT took 658.7 seconds, over three times longer. Similarly, in exploitation, PENTESTAGENT finished in 58.6 seconds, compared to 283.5 seconds for PENTESTGPT, demonstrating its more streamlined attack execution. While PENTESTAGENT took

longer in vulnerability analysis (698.8 seconds vs. 433.5 seconds), this additional time contributed to its higher success rate, ensuring a more accurate and actionable assessment.

The results confirm that PENTESTAGENT is both more effective and more efficient than PENTESTGPT. It achieves higher completion rates across all stages, particularly in intelligence gathering and

vulnerability analysis, which are critical for successful exploitation. Moreover, its lower overhead in intelligence gathering and exploitation makes it a more scalable and practical solution for real-world penetration testing. While its vulnerability analysis takes slightly longer, this trade-off results in more reliable and successful attack execution, solidifying PENTESTAGENT as a robust and efficient automated pentesting framework.